

Generative AI Risk in Industrial Control Systems

A Study for Critical Infrastructure Operators, Regulators, and Suppliers

The Author's Continuing Work

Version 29 — DRAFT

June 2026

Tim Roxey

Eclectic Technologies

*Intended Audience: Asset Owner/Operators, ICS Vendors and Suppliers,
Regulatory and Policy Staff, and Standards Community Reviewers
Parent Document: ISA Parent Framework for Cognitive Errors in
Generative AI Systems Deployed in Industrial Control Environments, V1.2*

Author's Preface and Statement of Ownership

This document is the original and continuing work of Tim Roxey, President, Eclectic Technologies. It is not the publication that appears on automation.com under the ISA Global Cybersecurity Alliance imprint, although it is the source from which that publication was derived.

The study grew from the author's longstanding independent research into the implications of artificial intelligence and generative AI for industrial control systems — work that predates any institutional engagement and that informs the author's ongoing advisory relationships with federal research and regulatory bodies. The Bright Line Criteria — the central policy contribution of this work — were developed by the author in the course of that independent research.

By June 2023, the document was in active development and in circulation with colleagues at Idaho National Laboratory and in the ICS supplier community for review and comment. On June 27, 2023, the author initiated outreach to the ICS supplier community to begin socializing the analysis and exploring forming a supplier-centric working group. On the same day, Andre Ristaino of ISA offered to host such a group within the ISAGCA structure. The author notes that INL would serve as the center of gravity for an initial engagement; the INL/ISA Supplier AI Workshop kickoff was held on July 18, 2023, organized by the author with support from INL colleagues.

Following the July workshop, in September 2023, the author entered into a separate arrangement directly with ISA/ISAGCA. Under that arrangement, ISA provided administrative infrastructure — meeting coordination, a Teams environment, SharePoint access, and working group member list management — for a Supplier Working Group that the author agreed to facilitate. The terms of this arrangement were summarized in the author's written communication to Andre Ristaino and Heidi Cooke at ISA dated September 29, 2023, which described the documents placed in ISA's system as 'my present files' and 'the base report,' and described ISA's role as providing 'Teams supports,' 'a possible SharePoint for collaboration,' and management of 'our invitees list.' ISA's administrative support did not constitute co-authorship of any version of this document. The author ran all working group meetings, set all agendas, and produced all written content throughout the working group's operation.

Version 20 of this document was provided to ISA for publication on automation.com. That publication, titled Briefing: AI Risks to Critical Infrastructure and dated April 14, 2025, was edited by ISA to conform to its house style and is attributed to the ISAGCA Supplier Working Group with acknowledgment of the author's role. The ISA publication represents a snapshot of the author's work as of Version 20. Versions 21 through the current version reflect continued independent development by the author subsequent to that submission and are not associated with ISA or ISAGCA in any capacity.

All intellectual content, analytical frameworks, risk taxonomies, Bright Line Criteria, and sector-specific analysis contained in this document are the original work of Tim Roxey, Eclectic Technologies. This document may be cited as:

Roxey, T.E. Generative AI Risk in Industrial Control Systems: A Study for Critical Infrastructure Operators, Regulators, and Suppliers. Version 29. Eclectic Technologies, 2026.

The ISA publication derived from Version 20 of this work may be cited as:

Roxey, T.E. Briefing: AI Risks to Critical Infrastructure. ISA Global Cybersecurity Alliance Supplier Working Group. Automation.com White Paper Series. April 14, 2025. Available at: <https://www.automation.com/en-us/assets/white-papers/briefing-ai-risks-critical-infrastructure>

Questions regarding this document, licensing, or use in standards development should be directed to the author at Eclectic Technologies.

Abstract

This paper examines the deployment of artificial intelligence systems across the United States' critical infrastructure sectors, distinguishing between the risk profiles of classical machine learning and generative AI technologies. Drawing primarily on examples from the energy and nuclear sectors, the paper proposes a regulatory Bright Line beyond which fully autonomous generative AI systems shall not operate without human oversight in critical control functions. This threshold recognizes the fundamental difference between deterministic machine learning systems, which can be verified through established testing methodologies, and non-deterministic generative AI systems, whose outputs cannot be fully validated prior to deployment and whose failure modes — hallucination, behavioral envelope exceedance, and automation complacency — fall outside the threat-actor-capability classification scheme that existing industrial control system security standards employ.

The paper introduces the Command Broker as the human decision authority required above the Bright Line. It establishes that the Command Broker function imposes qualification and governance obligations on Asset Owner/Operators that are independent of sector-specific regulatory requirements. It addresses four primary audiences — Asset Owner/Operators, ICS vendors and suppliers, sector regulators, and the broader national security community — and provides use cases, a sector-by-sector regulatory landscape, and technical appendices to ground the analysis in operational reality.

Abbreviations

The following abbreviations are used in this document.

Abbreviation	Description
AOO	Asset Owner/Operator
BA	Balancing Authority
BES	Bulk Electric System
BPS	Bulk Power System
CI	Critical Infrastructure
DERMS	Distributed Energy Resources Management System
EMS	Energy Management System
FERC	Federal Energy Regulatory Commission
GenAI	Generative AI — a category of Artificial Intelligence

Abbreviation	Description
IACS	Industrial Automation and Control System
ICS	Industrial Control System
ISAGCA	International Society of Automation Global Cybersecurity Alliance
LLM	Large Language Model
ML	Machine Learning
NERC	North American Electric Reliability Corporation
NIPP	National Infrastructure Protection Plan
NRC	Nuclear Regulatory Commission
PMU	Phasor Measurement Unit
RC	Reliability Coordinator
SCADA	Supervisory Control and Data Acquisition
STA	Shift Technical Advisor
WAMPAC	Wide Area Monitoring, Protection, and Control

1 Background

1.1 AI and Classical Risk

The potential of artificial intelligence in each of the sixteen critical infrastructure sectors in the United States and its influence on various risk categories is significant and extensive. This document examines AI's ramifications, particularly the nuances between generative AI and the broader category of machine learning, to inform the regulatory dialogue.

This document employs the traditional three-component risk framework, which combines threat, vulnerability, and consequence. Understanding AI's influence on risk requires examining how AI affects each of these three components independently and in combination. Critical infrastructure sectors are defined within the National Infrastructure Protection Plan framework. Each CI sector provides a service deemed vital to the United States' health, safety, or economy. The NIPP considers that harm to a CI sector element may necessitate a comprehensive, whole-of-government, public and private sector effort to respond; this public-private partnership approach is crucial for anticipating and addressing potential sector risks.

This paper reflects a common understanding of AI's implications, developed through sustained engagement with the ICS supplier community and subject-matter experts from disciplines related to the industrial control systems of these sixteen CI sectors. The use cases focus on the electricity and nuclear subsectors, but the underlying principles apply across all sectors. The focus is driven

by a detailed understanding of sector risks and the presence of mature regulatory regimes. Several remaining sectors are also regulated and may face similar issues and opportunities arising from AI in their operations. Sectors without federal or state regulators should treat the guidance in this paper as advisory.

1.2 The Gap in Current Frameworks

Industrial control system security has mature frameworks. IEC 62443 addresses security comprehensively, organizing requirements around Security Levels that reflect the capability of the threat actor the system is designed to resist. NERC CIP governs cybersecurity for the bulk electric system with enforceable reliability standards. NRC regulations govern digital instrumentation and control with quality assurance requirements tracing to the 1970s. These are serious, tested frameworks.

None of them were written for generative AI. The gap is structural, not incidental. IEC 62443 Security Levels classify threats by attacker capability — the right axis for cybersecurity, and the wrong axis for AI governance. A generative AI system does not fail because an attacker exceeded the system's designed resistance level. It fails because its outputs are non-deterministic: the same input can produce different outputs, the space of possible responses cannot be exhaustively enumerated, and conditions arise that were not anticipated during qualification testing. Behavioral envelope exceedance, hallucination, and automation complacency are AI failure modes; they have no home in a threat-actor-capability classification scheme.

The result is that organizations deploying AI in industrial control environments face two bodies of guidance — AI governance frameworks and ICS security frameworks — developed in parallel, addressing different failure modes, with no methodology for their integration. This paper proposes the Bright Line Criteria and the tiered assessment framework as the bridge between them. Sector-specific application is addressed in companion documents; the IEC 62443 AI Gap Analysis provides the normative mapping from these criteria to the existing IEC 62443 clause structure.

2 Intended Audiences

This document addresses four audiences whose stakes in AI deployment in critical infrastructure are distinct. The analysis that follows is written to be accessible to all four; the technical appendices provide grounding for specialist readers.

2.1 Asset Owners and Operators

After the release of ChatGPT-3 in November 2022, many AOO organizations began exploring the possibilities. For the corporate side of an AOO, the drivers for AI acceptance are process

improvement, information access, and customer support. For the operational side — where electricity is generated or distributed, water is treated, or other critical functions are performed — this paper addresses the specific challenge of using generative AI within industrial control systems where autonomous decision-making may be possible and where the consequences of error are potentially severe.

This paper states clearly that generative AI is not permissible for autonomous control in the highest-criticality control systems. In those systems, generative AI may operate only where a human Command Broker in the control loop makes the final decision about every control action. The non-deterministic nature of generative AI large language models renders variability in responses unacceptable for autonomous action above the Bright Line.

AOOs struggle with a genuine tension: new tools deliver real operational benefits but expose the organization to risks that may exceed current People, Process, and Technology capabilities. Generative AI deployed thoughtfully in ICS program management — maintenance scheduling, anomaly pattern recognition, compliance documentation, operator training support — can reduce operational risk in quantifiable ways. The question is not whether to engage with this technology. It is how to engage in a way that captures the benefits without accepting uncharacterized risk.

Uncharacterized risk is the worst risk management position available: you cannot manage, transfer, or insure what you have not identified. The design basis concept addresses this directly. A design basis document forces the AOO to characterize what is being protected, at what consequence level, before any deployment decision is made. Once characterized, risk can be governed through policy, procedure, and audit, and can be shifted through insurance to the extent that governance is demonstrably in place. An AOO who can demonstrate to an insurer a documented Command Broker qualification program, auditable procedures, and a design basis for the AI application presents a materially better risk profile than one who cannot. The governance investment returns value not through compliance avoidance but through risk positioning with direct financial consequences.

Even where no regulatory mandate exists, the prudent course is to develop policy, procedures, and audit mechanisms for the People, Process, and Technology elements of every GenAI deployment in an ICS context. Duty of care does not require a regulator. An organization that deploys a generative AI system in a highest-criticality application, knows that the Bright Line requires a Command Broker, and places an unqualified individual in that role has accepted foreseeable liability exposure that a reasonable organization should have anticipated and prevented.

This paper is intended to help AOO personnel better understand the differences between generative and non-generative forms of AI, so that they can be instrumental in helping the regulatory and supplier communities define minimum requirements for ICS systems.

2.2 Suppliers of ICS

For years, the industrial control systems supplier industry has debated the appropriate use of AI in its product offerings. This study addresses the distinction between machine learning's deterministic capabilities and the generative forms of AI, presenting use cases and a framework for defining risk. Suppliers are expected to refine this document by contributing additional use cases that demonstrate the distinction.

The Bright Line is a specification before it is a mandate. Vendors who architect their AI-enabled products to satisfy the Command Broker interface requirement — ensuring that the AI cannot directly execute control actions without affirmative human authorization — are building qualification records and product architectures that will survive the regulatory transition their competitors will scramble to address. Vendors who can provide AI system provenance documentation, structured against the tiered assessment framework, are serving an AOO procurement need that vendors who cannot are leaving unaddressed.

2.3 The Regulators

The Bright Line criteria concept applies to all CI sectors, though only a few have a sector regulator with enforcement authority. Regulators span federal, state, and local levels; AOOs must comply with all that apply.

Several regulators — the NRC and FERC/NERC foremost — have compliance management and enforcement processes designed to protect their sector's critical functions. The NRC establishes a nuclear safety basis; FERC and NERC establish a bulk power system reliability basis. Both have achieved the same result through different instruments: a safe and reliable provision of critical functions. This paper presents a framework to inform regulatory conversations on the use of AI in CI sector control systems.

The regulatory community should be aware that the gap this paper addresses is structural. Existing ICS security standards were written before generative AI existed as a deployed technology. Regulatory frameworks that extend existing cybersecurity standards to cover AI — without addressing the axis problem described in Section 1.2 — will govern the wrong failure modes. The Bright Line and tiered assessment framework are offered as analytical inputs for agencies developing AI-specific requirements.

2.4 The Generalist and National Security Reader

This paper simplifies the discussion of AI consequences and the distinction between machine learning and generative AI for readers without specialist ICS backgrounds. When OpenAI released ChatGPT in November 2022, it reached specialists and tens of millions of ordinary people simultaneously. The public concern about AI is understandable and legitimate. This paper argues that sector-specific regulatory engagement is the appropriate response — not blanket restriction or blanket permission, but consequence-tiered governance that distinguishes the applications where autonomous AI is acceptable from those where it is not.

3 An Analysis of Determinism and AI Use Cases

While working on digital upgrades to nuclear safety-significant systems during the 1990s, several practitioners realized that the code base for proposed digital replacements for analog circuits was too large for the software quality assurance methods known as formal methods. Richard Danzig, a former Secretary of the Navy, reopened this dialogue in early 2007 during a discussion on critical industrial control systems used on naval vessels. The problem he articulated remains: a computer-based ICS product cannot be deterministically secured when the code base exceeds the upper limit for formal methods analysis. Establishing behavioral assurance with a deterministically verified method is important; the complexity of ICS software often precludes it.

The word 'deterministic' is critical. Complex software-based systems struggle to provide high assurance because there are so many input paths through a complex system that it is difficult to rule out paths leading to undesirable performance. This is unacceptable for systems with critical or high-risk consequences. To address this while preserving the performance of modern ICS devices, methods were developed to wrap certain highly critical digital systems in deterministic, logic-based protective envelopes that could be fully tested for assurance, providing the benefits of modern ICS devices within the protection of a deterministically testable wrapper.

In the emerging field of AI, the machine learning branch can be deterministic by the nature of its algorithms. As cycles of use proceed, the ML algorithm can learn and adjust to improve performance. Although complex, semi-formal methods can verify these algorithms, including the first-principles derivation of base control equations. However, the more robust generative forms of AI involve complexities well beyond current deterministic assessment methods. It is this distinction — between the verifiable determinism of ML and the irreducible non-determinism of generative AI — that drives the Bright Line Criteria.

4 AI Risk in the Electric Sector

Utilities manage many types of risk in day-to-day operations: financial and market risks, extreme-weather risks, brand risks, and operational risks not directly related to industrial control systems. When assessing operational risk in electricity production and distribution, the focus falls on real-time ICS devices. Assessments of these devices involve a detailed review of threats, vulnerabilities, and consequences. The sections below focus on how AI affects each of these classical risk elements.

5 The Bright Line Criteria

5.1 Origin and Basis

At this point, a brief overview of the risks of deploying AI in the ICS space is appropriate. The Bright Line Criteria emerged from sustained engagement with the ICS supplier community — engineers and security professionals at the organizations building control systems deployed in electric utilities, water treatment facilities, nuclear plants, and other critical infrastructure. These practitioners understood intuitively what the standards frameworks had not yet articulated: the non-deterministic nature of generative AI creates a category of risk that cannot be managed by the same instruments used to manage deterministic system failures.

The Bright Line is not a boundary between criticality tiers; it is an action-level consequence threshold (FD-BL §4.2–§4.3). Criticality tiers set assessment rigor, while the line runs action by action through every tier — a highest-criticality application still contains below-line actions, and lower tiers may contain above-line ones.

5.2 The Bright Line Defined

The Bright Line, as defined in FD-BL v0.2 (§4.1–§4.5), establishes a threshold on actions: an action is above the line when its incorrect performance could produce a consequence at or above the facility's severity threshold, and below when it could not. An above-line action may not be taken by an unverifiable component autonomously; it requires a qualified human Command Broker in the control loop who authorizes or rejects it, enforced architecturally, regardless of assessed performance (§4.5). The criticality band of an application sets the rigor of assessment but does not decide placement — a highest-criticality application still contains below-line actions, and a lower-band application may contain above-line ones (§4.3). Non-determinism is the reason the broker is required where it is required (residual uncertainty cannot be discharged by testing), and it defines the scope carve-out (§4.4) — deterministic, formally testable-as-deployed components fall outside the obligation — but it is not itself the line: a deterministic component can produce an above-line action.

The criticality discussed below applies to the controlled system, not the AI system itself. An example of the highest criticality is the NERC CIP critical system for electric sector operations. Maloperation, misoperation, or intentional misuse of a NERC CIP critical system could cause a cascading outage — the specific condition underpinning NERC Standards under Section 215 of the Federal Power Act. Another example is an ICS device used in a safety-related system at a nuclear power plant, a core consideration in NRC regulations under Title 10 of the Code of Federal Regulations. Each of the remaining critical infrastructure sectors has its highest-critical applications; sector regulators should restrict autonomous generative AI in their operations accordingly.

5.3 Criticality Classification and GenAI Constraints

Application Criticality	Generative AI Role	Machine Learning Role	Regulatory Reference	Command Broker
Highest Criticality: Extreme consequences	Guides and advises the operator via a conversational interface—no autonomous action. Human authorization is required for every control action.	May operate in closed-loop for bounded, deterministic protective actions—extensive testing and red-teaming required.	NRC: Safety-Related NERC CIP-002: High Impact BES Cyber Systems	Required. The Command Broker must evaluate and authorize every GenAI-recommended action. No exceptions above the Bright Line.
Mid-Level Criticality Moderate consequences	Informs the operator of specific recommended actions; the operator decides which to execute—human in the command loop.	May autonomously implement bounded operational actions within defined envelopes—deterministic testability required.	NRC: Important to Safety NERC CIP-002: Medium Impact BES Cyber Systems	Required. Autonomous GenAI action is not acceptable. Command Broker evaluates recommendations before execution.
Lowest Criticality Limited consequences	May operate as a virtual assistant, taking limited autonomous actions within a well-defined, low-consequence scope.	Full autonomous behavior is acceptable within the tested performance envelope. Application testing per industry best practices.	NRC: Balance of Plant NERC CIP-002: Low Impact BES Cyber Systems	Not required. Autonomous operation is acceptable within the defined scope and operational envelope.

Note: Red-teaming refers to adversarial testing in which qualified personnel attempt to elicit unexpected, incorrect, or harmful outputs from the AI system under conditions representative of operational use. Red-teaming is required at all criticality levels; its scope and rigor scale with consequence level.

6 The Command Broker

6.1 Function and Architecture

The Command Broker is the human decision authority required above the Bright Line. The term emerged from supplier working group discussions and reflects a specific architectural and governance concept: the human in the control loop who evaluates AI recommendations and authorizes or rejects the corresponding control actions. The Command Broker is not a job title, a checkbox, or a warm body in the control room. It is a defined function with specific competency requirements, specific cognitive demands, and specific accountability obligations.

The Command Broker's protective function is architectural, not procedural. It does not depend on the operator's ability to detect every AI error independently. It depends on the physical separation between AI recommendation and control action — the AI system cannot directly command changes to setpoints, valve positions, breaker states, or other process control parameters without affirmative human authorization. That separation is what makes the architecture sound. But the architecture's soundness does not guarantee the function's effectiveness. A correctly implemented Command Broker interface that routes AI recommendations through a human who authorizes every output without genuine evaluation is architecturally compliant and functionally worthless.

A critical distinction applies here. The phrase 'there is a human in the loop' has become common in AI deployment discussions and performs the same reassurance function as 'the system is air-gapped' once did in cybersecurity. A board that hears 'there is a human in the loop' should treat it the way a security engineer treats 'the system is air-gapped' — as the beginning of an inquiry, not the end of one. The meaningful question is whether the system architecture makes it physically impossible for AI-generated recommendations to execute without affirmative human authorization, and whether that constraint is verifiable by a third party.

6.2 Command Broker Qualification

Establishing the Command Broker architecturally is necessary but not sufficient. The AOO bears a duty of care with respect to ensuring that the individuals performing the Command Broker function are qualified to perform it. This duty exists independently of sector-specific regulatory requirements, because the Command Broker function is safety-significant and because the harm that could result from an unqualified Broker performing the function is foreseeable.

Qualification for the Command Broker function requires competency in three domains. Process domain competency means the Broker must understand the specific process being managed — its normal operating envelope, its abnormal and emergency procedures, and the causal relationships between process variables sufficient to evaluate whether an AI recommendation is consistent with expected plant behavior. AI-interaction competency means the Broker must understand how generative AI systems behave and fail: the distinction between deterministic and non-deterministic systems, the hallucination failure mode, the concept of the AI system's operational domain boundary, and automation complacency as a cognitive risk. Decision authority competency means the Broker must be able to exercise independent judgment, reject AI recommendations when evaluation warrants it, articulate the basis for authorization or rejection decisions, and maintain evaluative discipline under time pressure.

The Command Broker Implementation Guide, a companion document in the Eclectic Technologies AI Governance Series, provides the full qualification framework, lesson plans, learning objectives, and tabletop exercise structure for AOOs establishing Command Broker programs. It is the AOO-facing operational complement to this document's policy framework.

7 Use Cases and Illustrative Narratives

7.1 The Automation Complacency Narrative

Conjectures about the evolution of AI use in grid management have emerged in several speculative narratives. In one notional grid narrative, grid operators initially benefit from AI-enabled tools, finding them helpful and valuable. Over time, as the tools prove useful, operators become increasingly dependent on them. At some point, operators allow autonomous control of grid breakers because AI has proven faster, less error-prone, and occasionally more creative than human operators. These narratives are fictional, but the dependency dynamic is real and documented in multiple operational domains.

A simpler illustration: imagine you are an ambulance driver recently relocated to a new city, and your GPS has failed. Dispatch gave you an address, and speed is essential. The deep AI applications that could navigate you around traffic snarls are unavailable. Your intimate familiarity with the streets — the knowledge base that GPS dependency has allowed to atrophy — is what you need, and it may not be there. The dependency dynamic in AI-augmented ICS operations follows the same pattern. Operators who have not been trained to maintain independent situational awareness and critical evaluation of AI output will find, when the AI is wrong, that the cognitive muscle for independent operation has weakened.

7.2 Use Case 1: From Machine Learning to Generative AI in Nuclear Operations

During the 1990s through approximately 2010, America's nuclear fleet underwent a digital transformation. The 64 nuclear plant sites and 104 operating nuclear plants relied on sophisticated printed circuit boards for certain safety-related process controls. These PCBs analyzed analog signals from transducers distributed across plant equipment, measuring temperatures, pressures, and flow rates, and took autonomous protective actions — including feedwater flow adjustments and reactor trips from full power — without operator intervention. These PCBs were tightly controlled through quality assurance programs and rigorous testing to assess actual logic circuit performance. This deterministic testing program assured safe reactor operations.

In the early 2010s, these safety-related PCBs were replaced with small industrial control systems running safety-related algorithms via software. The software code bases exceeded 20,000 lines, widely considered the practical upper limit for applying formal software quality assurance methods. This means deterministic behavioral assurance became difficult or impossible to establish. The substitution of performance testing for deterministic assessment was discussed in many NRC licensing submittals before these upgrades received final approval.

Fast-forward to today: machine-learning sensor networks are working well. System engineers can monitor systems using ML ICS devices and enable certain autonomous actions, such as plant trips or fine feedwater flow adjustments. A significant development is that these ML systems now feed into large databases spanning many individual plants across a company's domain. Several vendors collect operating data from thousands of installed system hours and use trained generative AI models to provide natural-language operator interface capabilities. This allows plant operators and vendor technicians to discuss plant performance issues beyond simple historical analysis.

Having a generative AI monitor safety-parameter inputs and produce an operating envelope assessment from real-time plant data is of real interest to plant operations. The Plant Shift Technical Advisor — a fully qualified Senior Reactor Operator working adjacent to the control room — could use such a tool to support control room operators. Such assessment capability is within the range of current generative AI models. The question is how much autonomous behavior to permit. The Bright Line answer is unambiguous: for this application, no automatic actions by the generative AI are acceptable. The AI is too non-deterministic for autonomous action in a safety-related context. Regulations codifying the Bright Line criteria would provide guidance, ensuring that supplier products permit ML algorithms to enable rapid plant-performance-adjusting reactions while requiring generative AI always to have a Command Broker in the loop.

7.3 Use Case 2: Orchestration of Prosumers Causes Grid Disruption

A distribution provider and balancing authority are investigating ways to optimize interactions among prosumers — end-use customers who can return energy to the distribution grid. Jim, a DERMS operator, relies on day-ahead forecasts from support vector machines to determine the maximum load an EV charging station can draw to maximize electricity distribution. As part of a virtual incident response team, Jim receives an invitation to a meeting where an inexplicable failure at the feeder connecting the EV charging station to the grid is being discussed. The SCADA system shows the feeder is disconnected. The SCADA operator concludes from the alarm summary that the feeder has been overloaded, disrupting service in the area it serves.

Jim reconstructs his operations through an activity logbook and recalls that his AI assistant advised him to set the limits based on the forecasting function. His AI assistant could also have operated in closed-loop mode, which would have classified this event as the highest criticality, triggering the Command Broker requirement. The incident response team confirmed that the EV charging station was the cause of the disruption. Jim manually orchestrated the station to consume less load while the SCADA operator reconfigured power system elements to restore the feeder. The incident destabilized grid operations and pushed contractual flexibility into an out-of-compliance condition.

The root cause analysis found: the system outside direct SCADA control was making decisions that could impact the grid's state; the DERMS operator set load levels based on ML inputs that

were subsequently shown to be incorrect; and the incident could have been prevented by integration between the SCADA and DERMS systems with software checks and consistent querying of real-time SCADA data. Had Jim's AI assistant been operating in closed-loop autonomous mode — above the Bright Line without a Command Broker — the incident would have unfolded without any human decision point at which the error could have been caught.

8 The Training of AI and Machine Learning Systems

An AI system is trained on a body of data and behavioral observations specific to its application domain. For grid operations, the AI can access operator data sources, including system one-line diagrams, SCADA signals, synchrophasor data, and EMS data. By observing human operators' responses to bulk power system telemetry, the AI makes time-relevant correlations and encodes these behaviors into its training. The training material is the same material operators use daily; the AI learns appropriate responses by observing operator behavior with respect to grid data.

Within microgrids, AI tools may offer unsupervised internal control. These AIs can be trained to manage microgrid outputs — including voltage, current, and phase angle — for energy injection into the aggregated grid, autonomously satisfying human-designated targets. This is a lowest-criticality application under the Bright Line framework: consequences are local and bounded, and full autonomous behavior is acceptable within the tested operational envelope.

The training domain boundary is a governance concern that the Command Broker must be equipped to assess. An AI system trained on historical operational data will have seen many contingency events. Still, it will not have been trained on every possible post-contingency network topology or every unusual operating condition. Recommendations that fall at or near the boundaries of the AI's training domain carry elevated uncertainty. The Command Broker's qualification requires that they understand how to identify domain boundary conditions and respond appropriately — including by deferring or rejecting recommendations until situational awareness is sufficient to evaluate them.

Appendix A: Critical Infrastructure Federal and State Oversight and Regulators

The United States designates sixteen critical infrastructure sectors, each with federal oversight coordination but with varying levels of oversight and enforcement. This appendix categorizes these sectors by regulatory framework, distinguishing those subject to mandatory federal regulation, those governed by voluntary risk management approaches, and those subject to specialized or hybrid oversight models.

Sectors with Federal Regulatory Authority

A limited number of critical infrastructure sectors operate under federal agencies with explicit statutory authority to promulgate and enforce regulations. The Nuclear Reactors, Materials, and Waste Sector operates under the regulatory authority of the Nuclear Regulatory Commission, which maintains comprehensive licensing and operational requirements for commercial nuclear facilities. The Communications Sector falls under the Federal Communications Commission, which regulates interstate and international communications services.

Within the Energy Sector, the bulk electric power system operates under a public-private regulatory partnership in which FERC has delegated certain reliability oversight functions to NERC, resulting in mandatory, enforceable Critical Infrastructure Protection standards. The Chemical Sector is subject to EPA oversight, enforcing requirements for chemical safety, security, and environmental protection. The Dams Sector presents a complex landscape varying by dam purpose and ownership: hydroelectric facilities fall under FERC authority, mining-associated dams under MSHA, and dams at nuclear facilities under NRC.

Sectors Operating Under Risk Management Frameworks

The majority of critical infrastructure sectors lack mandatory federal regulations and instead operate under voluntary risk management frameworks coordinated by designated Sector Risk Management Agencies. These sectors typically adopt industry-developed best practices rather than complying with enforceable government standards, though the quality and consistency of these practices vary considerably.

DHS serves as SRMA for the Commercial Facilities, Critical Manufacturing, Emergency Services, Information Technology, and Government Facilities sectors, providing coordination and voluntary guidance without regulatory enforcement authority. The Department of Energy serves as SRMA for the broader Energy Sector beyond the FERC/NERC-regulated bulk power system; TSA provides security oversight of oil and natural gas pipeline infrastructure through security directives and voluntary programs. The Department of the Treasury coordinates the Financial Services Sector, with regulatory oversight distributed among financial regulators based on institution type. Agriculture and HHS jointly coordinate the Food and Agriculture Sector; HHS coordinates the Healthcare and Public Health Sector, where healthcare delivery is primarily regulated at the state level. The Transportation Systems Sector operates under joint DHS/DOT coordination, with regulatory authority varying significantly by transportation mode. EPA coordinates the Water and Wastewater Systems Sector, with primary statutory authority focused on water quality standards rather than operational security or reliability. The Defense Industrial Base operates under DoD coordination.

Implications for Assurance of Operations

Regardless of whether a critical infrastructure sector operates under mandatory regulation or voluntary risk management frameworks, all sectors depend on supplier products and services reasonably free of defects. In sectors without regulatory oversight, this dependency on supplier quality becomes even more critical, as no regulatory backstop verifies the adequacy of component qualification, testing, or operational assurance. State-level regulation, when administered through Public Utility Commissions, typically focuses on economic regulation rather than comprehensive operational or security standards, creating additional variability in oversight rigor across jurisdictions.

This fragmented regulatory landscape creates significant challenges for establishing consistent quality assurance standards for emerging technologies such as AI systems that may be deployed across multiple critical infrastructure sectors simultaneously. The Bright Line criteria provide a sector-neutral governance instrument applicable across all sixteen sectors, with sector-specific elaboration in the companion application guides.

Appendix B: Synchrophasor Technology and Phasor Measurement Units

A synchrophasor is a device used in electric power systems to measure the voltage or current phase angles of electrical power at a specific point. The Phasor Measurement Unit records both the magnitude and phase angle of a sinusoidal electrical wave at a particular location and point in time. These measurements are recorded and transmitted at high sampling rates, typically 30 to 60 samples per second, with time-stamping accuracy of a few microseconds or better.

Synchrophasor measurements enable real-time monitoring and control of the power system. By comparing measurements from different locations across the grid, system operators can quickly identify and locate faults or disturbances, enabling corrective action to prevent cascading failures. Beyond immediate operational benefits, synchrophasors enable wide-area monitoring, control, and protection applications that improve situational awareness and optimize power system operation. As the grid becomes increasingly complex with the integration of distributed generation, renewable resources, and advanced control systems, synchrophasor technology is becoming essential to modern grid operations.

Appendix C: Energy Management Systems

The Energy Management System is a computer-based system used by reliability coordinators, independent system operators, balancing authorities, and electric utilities to monitor, control, and optimize the operation of the electrical grid. EMS systems provide real-time information on the

grid's status, including electricity flow, voltage levels, and equipment status across transmission and distribution networks.

EMS platforms employ advanced software algorithms to analyze data collected from the grid and make decisions on how to control and optimize grid operations. An EMS can automatically adjust power plant output or direct electricity flow to prevent overloading of transmission lines. These systems also support energy markets, enabling ISOs and utilities to buy and sell electricity in real time. EMS platforms provide operators with situational awareness and decision-support tools for responding effectively to emergencies and contingencies.

EMS systems are a critical component of the modern electricity grid, serving as the primary operational platform for reliability coordinators, balancing authorities, and transmission operators. They continue to evolve to meet the electricity industry's changing needs, including integration with renewable energy sources, demand response programs, synchrophasor networks, and advanced distribution management capabilities. The AI advisory systems addressed by this paper will, in most electric sector deployments, interface with or operate alongside EMS platforms, making EMS architecture an important consideration in Command Broker interface design.

Appendix D: Grid Control Functions

Balancing Authority

A balancing authority maintains the balance between electricity supply and demand within a specific geographic region, typically operating the transmission system, managing electricity flows, and ensuring grid stability and reliability within its designated area. The core responsibility is to balance electricity supply and demand in real time, primarily through Automatic Generation Control systems. AGC continuously monitors system frequency and net interchange schedules, automatically sending control signals to adjust generation at participating power plants to match fluctuating demand. AGC systems typically update generator setpoints every few seconds to maintain system frequency at its nominal value and keep actual power flows aligned with scheduled interchange values between balancing authority areas.

Supply-demand imbalances — even brief ones — cause system frequency to deviate from its nominal value, and sustained imbalances can lead to equipment damage, cascading failures, and blackouts. By automatically and continuously adjusting generation to match load through AGC, balancing authorities ensure the grid operates within acceptable frequency and interchange tolerance bands.

Reliability Coordinator

A reliability coordinator is responsible for ensuring the reliability, security, and stability of the bulk electric system within a specific geographic area, often spanning multiple balancing authority areas and utility service territories. In many regions, reliability coordinator functions are performed by Independent System Operators or Regional Transmission Organizations. Reliability coordinators monitor the grid in real time, analyze system conditions, and take action to maintain balance, prevent overloads, and mitigate equipment failures.

The reliability coordinator's role is fundamentally one of coordination and oversight across organizational boundaries, working continuously with transmission operators, balancing authorities, and generator operators. This coordination ensures that actions by individual entities support overall system reliability and that potential reliability threats are identified and addressed before they escalate. The reliability coordinator is the ultimate authority for real-time operations and emergency response within its coordination area — making it a critical context for Command Broker function requirements in AI-augmented operations.

Appendix E: Artificial Intelligence Learning Processes

Artificial intelligence systems learn through machine learning, which involves training algorithms to recognize patterns and make predictions based on data. The machine learning process follows a systematic progression from data acquisition through operational deployment.

The process begins with data collection, where relevant information is gathered from sources such as sensors, databases, and web scraping. Collected data undergoes preprocessing — removing duplicates, filling missing values, and converting to standardized formats. A representative subset is selected for training, covering the full range of conditions the algorithm will encounter and labeled with correct outcomes to provide ground truth. The training data is fed into the algorithm along with ground-truth labels, enabling the algorithm to learn to recognize patterns and make predictions based on input-output relationships.

After training, the algorithm is evaluated on a separate test set to measure accuracy and performance. This evaluation phase identifies areas needing improvement or additional training. Once trained and tested to acceptable performance standards, the algorithm can be deployed to perform real-world tasks. Deployment is not the final stage: ongoing monitoring and improvement remain necessary as the algorithm encounters new data or situations for which it was not originally trained. Continuous monitoring ensures the algorithm maintains accurate and efficient performance as operational conditions evolve.

For generative AI systems deployed in ICS contexts, this training and monitoring lifecycle must be documented in the system's provenance record, which the Command Broker uses to assess the reliability of recommendations. Changes to model training, fine-tuning, or retrieval augmentation sources after initial deployment constitute a material change to the AI system's operational

characteristics. They should trigger re-evaluation of the Command Broker qualification program for the affected application.

Informative References

Roxey, T.E. ISA Parent Framework for Cognitive Errors in Generative AI Systems Deployed in Industrial Control Environments. Version 1.2. Eclectic Technologies, April 2026.

Roxey, T.E. IEEE Framework for Verification and Validation of Cognitive Behaviors in Generative AI Systems Deployed in Industrial Control Environments. Version 1.3. Eclectic Technologies, 2026.

Roxey, T.E. Command Broker Implementation Guide. Version 0.1. Eclectic Technologies, June 2026.

Roxey, T.E. Briefing: AI Risks to Critical Infrastructure. ISA Global Cybersecurity Alliance Supplier Working Group. Automation.com White Paper Series. April 14, 2025. Available at: <https://www.automation.com/en-us/assets/white-papers/briefing-ai-risks-critical-infrastructure> [Derived from Version 20 of this work.]

IEC 62443 Series, Security for Industrial Automation and Control Systems. International Electrotechnical Commission.

IEC 61508, Functional Safety of Electrical/Electronic/Programmable Electronic Safety-related Systems. International Electrotechnical Commission.

NIST AI Risk Management Framework (AI RMF 1.0). National Institute of Standards and Technology, January 2023.

NIST SP 800-82 Rev. 3, Guide to Operational Technology (OT) Security. National Institute of Standards and Technology.

North American Electric Reliability Corporation. Critical Infrastructure Protection Standards, CIP-002 through CIP-014. Available at: <https://www.nerc.com/pa/Stand/Pages/CIPStandards.aspx>

Nuclear Regulatory Commission. Title 10, Code of Federal Regulations, Parts 50 and 52. U.S. Government Publishing Office.

Document Revision History

Version	Date	Author	Description
V1-V20	2022-2024	T. Roxey	Original development through ISA working

Version	Date	Author	Description
			group facilitation. V20 submitted to ISA/ISAGCA for publication on automation.com (published April 14, 2025, as Briefing: AI Risks to Critical Infrastructure).
V21-V28	2024-2026	T. Roxey	Continued independent development by the author subsequent to ISA submission. Expansion of the Bright Line framework, sector-specific analysis, and the Command Broker concept. No ISA/ISAGCA involvement in revisions post-V20.
V29	June 2026	T. Roxey	Full document rebuild. New title and subtitle. Author's Preface and Statement of Ownership inserted. Attribution corrected throughout. Expanded Command Broker section (Section 6). AOO governance and risk economics section added (Section 2.1). The regulatory axis problem is framed explicitly (Section 1.2). Appendix E added—informative references updated to the current document library.